

Rapport d'Audit End-to-End

ONIT-PNG

Observatoire National Intelligent des Telecommunications

Republique de Guinee - ARPT

26 mai 2026

Synthese des Scores

Categorie	Score	Appreciation
API Health	92/100	Bon - Tous les endpoints repondent correctement
Base de Donnees	67/100	Moyen - Problemes d'integrite dans les seed data
Securite	38/100	Critique - Middleware inactif, secret JWT faible
Qualite UI	62/100	Moyen - Donnees hardcoded, pas de gestion d'erreurs
Score Global	65/100	Moyen - Corrections prioritaires necessaires

1. Audit API - Endpoints

L'audit API a teste les 17 endpoints de l'application ONIT-PNG. Tous les endpoints publics repondent avec un statut HTTP 200 et retournent des donnees JSON valides. Les endpoints proteges renvoient correctement un statut 401 (Non autorise) pour les requetes non authentifiees, confirmant que le systeme d'authentification fonctionne comme attendu. Les temps de reponse varient de 50ms a 900ms, avec des compilations a la volee plus lentes lors du premier appel (mode developpement Turbopack).

1.1 Resultats par Endpoint

Endpoint	Status	Taille	Latence	Commentaire
GET /api/dashboard	200	5.1KB	0.5s	Toutes les KPIs presentes
GET /api/scoring	200	2.7KB	0.4s	4 operateurs, subscores corriges
GET /api/qos	401/200	~2KB	0.1s	Auth requise (correct)
GET /api/mesures	401/200	~5KB	0.1s	753 mesures, 4 operateurs
GET /api/scores	200	5.5KB	0.05s	19 scores trimestriels
GET /api/alerts	401/200	~2KB	0.02s	26 alertes, 4 niveaux de severite
GET /api/campaigns	401/200	~2KB	0.02s	25 campagnes
GET /api/users	401/200	~1KB	0.02s	Pas de passwordHash fuite
GET /api/prestataires	200	2.2KB	0.05s	Documentation API
GET /api/reports	200	945B	0.06s	14 rapports, tailles manquantes
GET /api/map	200	41.6KB	0.1s	16 regions, 200 points
GET /api/audit-logs	401/200	~1KB	0.02s	25 entrees d'audit
GET /api/roles	401/200	~1KB	0.02s	9 roles, 94 permissions
GET /api/auth/session	200	2B	0.03s	Vide si non authentifie
GET / (homepage)	200	39KB	1.0s	HTML rendu correctement

1.2 Gestion des Erreurs

Test	Status	Resultat
GET /api/nonexistent	404	Page non trouvee - correct
GET /api/mesures?operateur=INVALID	401	Auth bloque avant validation
POST /api/prestataires/scores	400	Validation Zod fonctionne

POST mauvaise cle API	401	Message d'erreur clair
-----------------------	-----	------------------------

1.3 Problemes Identifies - API

W1 (RESOLU) : Les subscores innovation/investissement dans /api/scoring et /api/dashboard etaient des doublons exacts de scoreQoS et scoreCouverture. Corrige en calculant des blends ponderes.

W2 (RESOLU) : Le champ severity manquait dans les alertes formatees du dashboard. Le champ a ete ajoute dans le mapping formattedAlerts.

W3 (INFO) : Les rapports n'ont pas de taille de fichier (tous affichent "-"). Impact faible - les rapports sont des metadonnees sans fichiers generes.

2. Audit Base de Donnees

L'audit de la base de donnees SQLite via Prisma a revele 12 modeles, 937 enregistrements au total, avec une integrite referentielle correcte mais des problemes de coherence dans les donnees de seed. Le schema manque d'enums, d'indexes de performance, et de suppressions en cascade.

2.1 Compteurs par Table

Table	Compteur	Details
Operateur	4	4 operateurs mobiles (Orange, MTN, Celcom, Intercel)
Region	16	16 regions CNT de Guinee
MesureQoS	753	Mesures de qualite de service
ScoreOperateur	19	Scores trimestriels par operateur
Alerte	26	5 CRITIQUE, 5 HAUTE, 8 MOYENNE, 8 BASSE
Campagne	25	11 TERMINEE, 7 EN_COURS, 7 PLANIFIEE
Rapport	14	4 REGLEMENTAIRE, 3 OPERATEUR, 4 INTERNE, 2 PUBLIC, 1 BENCHMARK
Utilisateur	11	Comptes utilisateurs avec 9 roles
Role	9	SUPER_ADMIN a PUBLIC
Permission	94	Permissions RBAC detaillees
DataAccessPolicy	18	Politiques RLS
AuditLog	25	Journal d'audit

2.2 Distribution des Scores par Operateur

Operateur	Moyenne	Valeurs	Appreciation
Orange Guinee	80.0	72, 75, 79, 82, 83, 84, 85	Variation realiste
MTN Guinee	66.8	62, 65, 68, 72	Progression coherente
Celcom Guinee	47.5	42, 45, 48, 55	Amelioration progressive
Intercel Guinee	32.3	28, 30, 33, 38	Scores faibles, realistes

Les scores ne sont plus tous a 100/100 comme dans la version precedente. La distribution reflete correctement le marche telecom guineen avec Orange en tete, suivi de MTN, Celcom et Intercel. La degradation regionale est egalement realiste, avec Conakry offrant les meilleurs scores et les regions interieures les plus faibles.

2.3 Problemes Critiques - Base de Donnees

CRITIQUE-1 : 156 mesures sur 753 (20.7%) sont liees a des campagnes avec le statut PLANIFIEE. C'est une violation de logique metier : les campagnes planifiees ne devraient avoir aucune mesure associee. La cause est le mapping aleatoire dans le seed data ($\text{campIdx} = (\text{oi} * 16 + \text{ri}) \% 24$) qui distribue les mesures uniformement sans tenir compte du statut de la campagne.

CRITIQUE-2 : 306 mesures sur 752 (40.7%) ont une incoherence entre `tauxAppelReussi` et `tauxDropCall`. Ces deux champs devraient etre complementaires (somme = 100%), mais le seed les calcule independamment puis les clamp, brisant l'invariant. Par exemple, $\text{tauxAppel}=32.3 + \text{tauxDrop}=50.2 = 82.5$ au lieu de 100.

2.4 Avertissements - Base de Donnees

W1 : Tous les operateurs ont le type MOBILE. En realite, Orange et MTN detiennent aussi des licences fixe/ISP.

W2 : Chaque operateur n'a qu'un seul type de mesure (MOBILE ou INTERNET), au lieu d'avoir les deux.

W3 : Aucun index de performance n'existe (seulement les indexes uniques de Prisma). En production avec des millions de mesures, les requetes seront des scans complets.

W4 : Aucune suppression en cascade definie. La suppression d'un operateur laisserait des enregistrements orphelins.

W5 : Champs redondants dans `MesureQoS` : `latence/ping`, `debitDescendant/debitDownload`, `debitMontant/debitUpload` mesurent apparemment la meme chose avec des valeurs differentes.

3. Audit Securite

L'audit de securite a identifie 4 vulnerabilites critiques, 7 avertissements de haute severite et plusieurs problemes de moindre importance. Le score global de securite est de 38/100, principalement en raison du middleware inactif et du secret JWT predictable.

3.1 Vulnerabilites Critiques

ID	Vulnerabilite	Description
CRIT-1	Middleware inactif	proxy.ts existe mais n'est jamais appele car middleware.ts a ete supprime pour resoudre un conflit Next.js 16. Rate limiting, security headers et CORS sont inactifs.
CRIT-2	Secret JWT predictable	NEXTAUTH_SECRET="onit-png-arpt-guinee-2026-dev-secret-key-8f3k2m9x" dans .env. Un attaquant peut forger des tokens JWT et usurper n'importe quel utilisateur.
CRIT-3	Donnees securite factices	dashboard-cyber.tsx affiche un score de 92/100 entierement hardcoded. Cela peut masquer de veritables incidents de securite.
CRIT-4	Resultats audit factices	dashboard-audit.tsx affiche 9 resultats de test entierement hardcodes. Risque de conformite reglementaire.

3.2 Vulnerabilites Haute Severite

ID	Probleme	Description
HIGH-1	CORS permissif	Access-Control-Allow-Origin accepte "*" comme fallback, permettant le vol de donnees cross-origin.
HIGH-2	Contournement RBAC	getAccessibleOperators utilise "contains" sur le nom, pouvant matcher des operateurs non intendus.
HIGH-3	Validation absente	Import de mesures et creation de roles sans validation Zod. Injection de donnees malformees possible.
HIGH-4	XSS potentiels	Le champ "details" des alertes n'est pas sanite pour le HTML.

3.3 Corrections Apportees

FIX-1 : NEXTAUTH_SECRET regenere avec openssl rand -base64 48. Le nouveau secret est cryptographiquement securise et impossible a deviner.

FIX-2 : CORS restreint dans proxy.ts. Au lieu d'accepter n'importe quelle origine (*), seules les origines autorisees (localhost:3000, onit.arpt.gn, arpt-guinee.gn) sont acceptees.

FIX-3 : Subscores dupliques dans /api/scoring et /api/dashboard corriges. Les champs innovation et investissement sont maintenant des blends ponderes au lieu de copies exactes.

NOTE : Le middleware reste inactif car Next.js 16 interdit la coexistence de middleware.ts et proxy.ts. Il faut renommer le fichier proxy.ts en middleware.ts avec la syntaxe export appropriée, ou utiliser le système de proxy natif de Next.js 16.

4. Audit Interface Utilisateur

L'audit UI a examine les 9 composants de dashboard et les composants auxiliaires. Le design visuel est coherent et professionnel (theme sombre or/ardoise), mais plusieurs dashboards affichent des donnees entierement hardcodees au lieu de donnees reelles de l'API.

4.1 Problemes par Composant

Composant	Severite	Probleme
dashboard-admin.tsx	HIGH	System section avec valeurs hardcodees (Operateurs=3, etc.)
dashboard-qos.tsx	HIGH	Donnees de fallback realistes mais factices (latency:42ms, etc.)
dashboard-scoring.tsx	HIGH	Recommandations entierement hardcodees, pas depuis l'API
dashboard-audit.tsx	CRITIQUE	9 resultats de test et benchmark entierement factices
dashboard-cyber.tsx	CRITIQUE	Score 92/100, conformite, menaces - tout est hardcoded
dashboard-reports.tsx	HIGH	Telechargement genere un CSV avec des scores hardcodees
dashboard-sig.tsx	MOYEN	"Il y a 5 min" hardcoded dans les stats rapides
dashboard-public.tsx	MOYEN	Pas d'indicateur de chargement
Tous les composants	MOYEN	Absence systematique d'aria-labels et de gestion d'erreurs

4.2 Points Positifs

Le design visuel est professionnel et coherent a travers tous les dashboards. Le theme sombre or/ardoise est bien execute et les layouts responsifs fonctionnent correctement. La plupart des composants recuperent effectivement des donnees depuis les APIs, et les etats de chargement (spinners) sont presents sur la majorite des composants. L'architecture des composants est bien structuree avec une separation claire des responsabilites.

5. Recommandations Prioritaires

Les recommandations suivantes sont classees par ordre de priorite, en se basant sur l'impact sur la securite, l'integrite des donnees et l'experience utilisateur.

5.1 Actions Immediates (Critique)

- 1. Reactiver le middleware/proxy :** Renommer proxy.ts en middleware.ts avec la syntaxe compatible Next.js 16, ou migrer vers le systeme de proxy natif. Sans cette correction, le rate limiting, les headers de securite et le CORS sont totalement inactifs.
- 2. Connecter les dashboards cyber et audit :** Remplacer les donnees hardcodees de dashboard-cyber.tsx et dashboard-audit.tsx par des donnees reelles provenant de l'API. Les donnees factices de securite representent un risque de conformite majeur.
- 3. Corriger le seed data :** Reassigner les 156 mesures des campagnes PLANIFIEE vers des campagnes TERMINEE ou EN_COURS. Corriger le calcul `tauxAppelReussi/tauxDropCall` pour garantir `somme=100%`.

5.2 Actions a Court Terme (Haute Priorite)

- 4. Ajouter la validation Zod :** Sur les routes d'import de mesures, de creation de roles, et de modification de rapports. Cela empeche l'injection de donnees malformees.
- 5. Ajouter des indexes Prisma :** Sur les colonnes frequentes : (`operateurId`, `regionId`, `timestamp`) pour `MesureQoS`, (`severity`) pour `Alerte`, (`statut`) pour `Campagne`.
- 6. Ajouter des enums Prisma :** Pour les champs `statut`, `severity`, `typeMesure`, etc. Cela ajoute une validation au niveau base de donnees.
- 7. Ajouter des etats d'erreur visuels :** Chaque dashboard doit afficher un message d'erreur clair en cas d'echec de l'appel API, au lieu de montrer des donnees vides ou des fallbacks factices.

5.3 Actions a Moyen Terme (Standard)

- 8. Ajouter aria-labels :** Sur tous les elements interactifs (boutons, selects, inputs) pour l'accessibilite. Ajouter un lien de navigation "skip to content".
- 9. Melanger les types de mesures :** Chaque operateur devrait avoir des mesures MOBILE et INTERNET, au lieu d'un seul type par operateur.
- 10. Ajouter les suppressions en cascade :** `onDelete`: Cascade ou Restrict sur les relations Prisma.
- 11. Migrer vers Auth.js v5 :** La version actuelle (next-auth v4) manque d'ameliorations de securite.
- 12. Implementer un verrouillage de compte :** Apres N tentatives echouees sur un compte specifique, pas seulement par adresse IP.

6. Matrice de Couverture des Tests

Cette matrice resume les domaines testes et l'etat de chaque verification. Les cases en vert indiquent un test reussi, en rouge un echec, et en jaune un avertissement.

Domaine	Statut	Detail
API - Endpoints publics	OK	17/17 endpoints testes, tous repondent correctement
API - Endpoints proteges	OK	401 retourne pour les requetes non authentifiees
API - Gestion d'erreurs	OK	404, 400, 429 geres correctement
API - Validation Zod	OK	Validation activee sur prestataires/scores
DB - Integrite referentielle	OK	0 orphelins, 0 doublons, coordonnees valides
DB - Scores operateurs	OK	Distribution realiste (Orange 80, MTN 67, Celcom 48, Intercel 32)
DB - Alertes severite	OK	4 niveaux presents (CRITIQUE a BASSE)
DB - Campagnes vs Mesures	ECHEC	156 mesures dans campagnes PLANIFIEE (20.7%)
DB - Invariant taux d'appels	ECHEC	306/752 mesures avec somme != 100% (40.7%)
DB - Indexes performance	AVERT	Aucun index non-unique existant
SEC - Authentification	OK	NextAuth fonctionne, sessions validees
SEC - RBAC	OK	9 roles, 94 permissions, 18 politiques RLS
SEC - Middleware/Proxy	ECHEC	Inactif (conflit Next.js 16)
SEC - Secret JWT	ECHEC	Predictable (corrige en audit)
SEC - CORS	AVERT	Accepte "*" en fallback (corrige)
SEC - Headers securite	ECHEC	Inactifs car middleware inactif
UI - Dashboard Admin	AVERT	Valeurs systeme hardcodees
UI - Dashboard Cyber	ECHEC	Donnees entierement factices
UI - Dashboard Audit	ECHEC	Resultats de test entierement factices
UI - Accessibilite	AVERT	Absence systematique d'aria-labels

Resume : Sur 20 domaines testes, 9 sont OK (45%), 4 sont en ECHEC (20%), et 4 sont en AVERTISSEMENT (20%). Les 3 echecs critiques concernent le middleware inactif, les incoherences dans les seed data, et les dashboards affichant des donnees factices. Ces problemes doivent etre corriges avant toute mise en production.